P3. Assignment 3.3 SSH Configuration and Hardening -Canvas-

SSH Configuration and Hardening

Secure SHell (SSH)

The IETFLinks to an external site. defines the **The Secure SHell (SSH) Protocol Architecture** in RFC 4251Links to an external site. as:

The Secure Shell (SSH) Protocol is a protocol for secure remote login and other secure network services over an insecure network.

While multiple authentication backends which interoperate with the SSH protocol exist, we will focus on two: password (memorized secret) authentication and public key authentication.
The following supporting slides Download supporting slidescan help to better understand the concepts put into practice here.

Deliverables and Submission

- Submit in **Canvas** a report in PDF with the numbered screenshots of Parts 1 to 3 and the explanation to the comprehension question in Part 4.
- We will have access to the system you have being working on, so we can assess your work there and their relation to the screenshots you submitted.

Architecture

In this lab, you will be using the Linux system available to you in the cloud. You will be touching the System Authentication, so **we encourage you carefully think in your actions before taking them so you do not lose access to your system. If this is the case you will need to start your work in this assignment from the beginning**.

Here you can find your user and assigned port here

You need to use the same password that you have to access the master server, BUT you will not be connecting to the master server, PLEASE use the corresponding port from the previous list. NOT 10010

When you connect to your system, you should see something like this:

ssh userid@cy5001.mscy.org **-p 200XX**

userid@cy5001_lab3:~$

Password Authentication

Password-based authentication requires the least amount of setup. Assuming that the sshd service is running on the target system, it is possible to login with the following syntax:

ssh -o PreferredAuthentications=password -o PubkeyAuthentication=no ${user}@${host}

It is not strictly necessary to pass the options explicitly enabling password authentication and disabling public key authentication. However, as a general rule, public key authentication should be preferred over the use of a password. This option is configurable in the ${HOME}/.ssh/config file of the user executing the above command.

Part 1. Configuring sshd service and connecting to it

Verify that your system has running the sshd server.

```
$ service ssh status
 * sshd is running
```

AND

```
$$ netstat -ntlp
(No info could be read for "-p": geteuid()=1001 but you should be root.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address          Foreign Address        State       PID/Program name
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
```

- *As you can see in this list, SSH is running at the default port 22. However, you are connecting through a different port. This is because these Linux systems are accessed through a proxy that maps your assigned port (200XX) to port 22 on your system.*

Submit screenshot-1 showing that you were able to login to the Linux VM over ssh from your host computer using password-based authentication.

Part 2. Public Key Generation and SSH configuration

- While the default daemonLinks to an external site. for sshd configured in the /etc/ssh/sshd_config is fairly secure, it prioritizes compatibility over security. To harden its configuration, a good starting point is the OpenSSH security configurationLinks to an external site..
- The easiest thing to do for the greatest immediate benefit is to completely disable password authentication (*Part 3*) and require the use of public keys. This renders brute-forcing against the SSH service unfeasible and requires that an attacker have some other exploitable vulnerability in order to gain access. It is also possible to completely disable the user's password as a method of authentication while still allowing login via OpenSSH by modifying the /etc/shadow file.
- Since a strong configuration will reject password-based authentication, a pubic-private ssh key-pairLinks to an external site. is needed for remote administration of the box. Recent versions of OpenSSH allow the use of fastLinks to an external site. elliptic curve cryptographyLinks to an external site., which provides the security of RSALinks to an external site.. 256-bit Ed25519 keys provide security equivalent to ≈3000-bit RSA keys, according to their inventorLinks to an external site., cryptographer Daniel J. Bernstein. Using them is advantageous because of they are comparatively more secure, but have lower computational cost and memory usage than RSA, especially on embedded devices.
- Generating an SSH keypair is accomplished with the ssh-keygenLinks to an external site. command:
    - Specifying the -o flag saves the key in the new OpenSSH format which provides better resistance against brute force decryption attack.
    - -o: Causes ssh-keygen to save private keys using the new OpenSSH format rather than
    - the more compatible PEM format. The new format has increased resistance to
    - brute-force password cracking but is not supported by versions of OpenSSH prior

to 6.5. Ed25519 keys always use the new private key format.

    - The -a flag is used to specify the number of rounds the key derivation functionLinks to an external site. should use (with the supplied passphrase) to encrypt the key. A higher number will require increased computational power and will magnificently slow down cracking attempts if the private key is stolen, in case.

- -a: When saving a new-format private key (i.e. an ed25519 key or when the -o flag is
- set), this option specifies the number of KDF (key derivation function) rounds
- used. Higher numbers result in slower passphrase verification and increased

resistance to brute-force password cracking (should the keys be stolen).

- OpenSSH provides the option of giving the key a **comment** so that it can more easily be identified in the authorized_keysLinks to an external site. fileLinks to an external site. on a remote host, which can be useful if access for a particular key needs to be revoked.

1. Generate either an Ed25519 key using ssh-keygen on *your host system*.

Submit screenshot-2 showing the output of the ssh-keygen command on your host laptop machine.

In order for public key authentication to work with OpenSSH, the public key of the newly-generated **SSH key** needs to be present on the remote host in the ${HOME}/.ssh/authorized_keys file of the user to login as. One benefit of using Ed25519 instead of RSA keys is that the public key is short enough that we can also type it directly into the ${HOME}/.ssh/authorized_keys file without too much trouble.

2. Configure the public key you just generated into your Linux VM (or docker container) for the user you created, so it can be used to authenticate your connections instead of using a password. It is important to disable password-based authentication over SSH, especially for root, as soon as a new server is provisioned. The file system permissions on both the .ssh directory and the authorized_keys file must not be too permissive, and must be owned by the correct user.

Submit screenshot-3 showing the permissions of the .ssh directory on the Linux VM.

Submit screenshot-4 showing the contents of the .ssh/authorized_keys file on the Linux VM.

Submit screenshot-5 showing a successful connection to the VM using public key authentication.

- OpenSSH public key authentication works by using one of various asymmetric cryptographic algorithms to generate a public-private keypair. The public key is present on the server in the ${HOME}/.ssh/authorized_keys file of the user the client wishes to authenticate as. OpenSSH uses Diffie-Hellman Key Exchange to set up an ephemeral session key (shared secret) to symmetrically encrypt the connection between the client

and server. Once the session is encrypted, the key-based authentication can be attempted by the client. First, the client sends the ID of the public-private keypair they wish to use, which the server then checks against the appropriate user's ${HOME}/.ssh/authorized_keys file. Assuming that it is present, the server uses the public key to encrypt a random number and sends it to the client machine (over the symmetrically encrypted ssh connection). If the corresponding private key is properly configured on the client machine, the client will successfully decrypt the random number, combine it with the session key and send the hash of this combined value to the server. The server compares this response with its independent computation of the hash of the session key, and the random number it encrypted and sent to the client. If these two values are identical, then the client is successfully authenticated and is able to log into the server (or may run a forced command, depending on the configuration).

3. Now repeat the process, but this time, create a brand-new user account on your system named cy5001. You may choose any password for this user and should verify that you can log in using the new credentials.

Next, configure public key authentication for the cy5001 user using the following public key:

ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIDzkQDQwE55NkKCOtxhBvjq9uWq6QWwPsAaX6SuuG/p+
cy5001@

>> You do not have access to the corresponding private key. We will test your SSH configuration as part of the lab assessment.

Part 3. SSHD configuration hardening

- There are a good number of guides that you can use in order to prevent the common vulnerabilities of SSH and Linux systems. Below, you can find some examples that all agree in regard to most of the limitations that need to be configured into the "**/etc/ssh/sshd_config**" file.
    - Guide 1Links to an external site.
    - Guide 2Links to an external site.
    - Guide 3Links to an external site.
    - Guide 4Links to an external site.
- Because of the particularities of the Linux system you are working, there are some limitations related to the audit capabilities. Every time you restart the SSH service, make

sure that:

- PAM module does not require UID identification for auditing proposes in file /etc/pam.d/sshd
    - session **optional** pam_loginuid.so
- SYSLOG package is installed, and is running (ps aux | grep [r]syslogd). You might need to install it and run it manually if it is not (rsyslogd -n).

1. Modify the sshd_config file of your Linux VM accordingly, so that password-based authentication CANNOT be used, only public-key. Remember that there is a section in the configuration file about it: #PasswordAuthentication. You may also need to touch ChallengeResponseAuthentication.
    - One of the worst situation we can face while protecting any information system is when the *system administrator's account* is compromised. For that reason we need to reduce the exposure of that account as much as possible.
2. Forbid root authentication through SSH connections. There is a section in the configuration file to tweak this option: #PermitRootLogin
    - All of the previous actions are intended to **prevent** hackers from accessing to our system. However, we can't know for sure if this will be enough, which is why we need to deploy different security measures. In case the first line of protection fails, we will still be able to reduce the impact of that potential attack. One of the best ways of reducing that impact is to **detect and react** to that intrusion as soon as possible. SSH server provides a configuration setting to improve the information that is logged and facilitates early detection and a fast reaction. This setting is #LogLevel and by default is set to INFO (Informational), but it can be upgraded to VERBOSE, so we can collect as much information as possible from successful/unsuccessful SSH connections attempts.
3. Modify SSHD configuration file in your Linux VM, so the maximum level of logs is collected from any SSH connection attempt. After restarting the SSHD service in your Linux VM, try several SSH connections from your host machine (valid and invalid). Make sure that rsyslogd is running (start it if it is not) and identify those connections in the logs file '/var/log/auth.log' or '/var/log/secure' or /var/log/syslog' (the name of the file might vary depending on the version of Linux in use).

Submit screenshot-6 where logs from your last connections to your Linux VM's SSH service appear.

- Finally, as a **deterrent** countermeasure, let's change the *welcome banner message* that your Linux VM SSH service provides. The idea is to alert everybody trying to access the system, about the consequences they may face in case they are unauthorized to use this system. You'll find different examples of this within some of the hardening guides we listed above. Those may help you perform the task that you need to in order to configure your system and provide the banner message.

```
**************************************************************************

                    NOTICE TO CY5001 USERS


This system is part of the CY5001 infrastructure. It is for authorized
use only. Users (authorized or unauthorized) have no explicit or implicit
expectation of privacy.


**************************************************************************
```

4. Configure your Linux VM to provide an updated *CY5001 Authorized Use Only* message when a user tries to connect to it over SSH. You can choose the method you want: Doing it prior to the authentication process (/etc/issue.net) or after the authentication has completed (motd). You can find descriptions about how to do it in *guide 3* and *guide 4*.

Submit screenshot-7 showing the banner of the SSH connection attempt.

Part 4. Classify the security controls you put in practice.

- As a wrap-up task for this lab, classify the hardening actions you performed using a common taxonomy of cybersecurity controls based on their objective. In this activity, security controls are grouped according to whether their primary purpose is to prevent, detect, or correct a security issue.
    - **Preventive controls** are security measures designed to stop a security incident before it occurs by reducing vulnerabilities or blocking unauthorized activity.
    - **Detective controls** are security measures designed to identify when a security incident or suspicious activity has occurred or is occurring.

- **Corrective controls** are security measures designed to limit damage and restore systems after a security incident has been detected.

- Go over all the tasks you performed in Parts 1, 2, and 3 of this assignment and classify them into one of the three objective-based categories listed above. For each control, provide the rationale you used to determine the category that best reflects its primary objective.
    - If there is a category for which you cannot find any security control applied in this assignment, review the previous assignments (Projects 1 and 2 included) and include at least two security controls applied there, along with the rationale supporting your classification.

Submit your classification and explanations in your assignment report.

Grading rubric

Please see here the rubric for the assignment:

Concept	**Points**
Part 1: Access and Verify your individual SSH system	10
Part 2: Your user's Key-Pair generation and configuration	20
Part 2: CY5001 user public key access configuration	20
Part 3: SSHD configuration hardening	40
Part 4: Cybersecurity Controls	10

WE'VE BEEN TRYING FOR DECADES TO GIVE PEOPLE GOOD SECURITY ADVICE.
BUT IN RETROSPECT, LOTS OF THE TIPS ACTUALLY MADE THINGS WORSE.
MAYBE WE SHOULD TRY TO GIVE BAD ADVICE?
I GUESS IT'S WORTH A SHOT.
SECURITY TIPS
(PRINT OUT THIS LIST AND KEEP IT IN YOUR BANK SAFE DEPOSIT BOX.)
• DON'T CLICK LINKS TO WEBSITES
• USE PRIME NUMBERS IN YOUR PASSWORD
• CHANGE YOUR PASSWORD MANAGER MONTHLY
• HOLD YOUR BREATH WHILE CROSSING THE BORDER
• INSTALL A SECURE FONT
• USE A 2-FACTOR SMOKE DETECTOR
• CHANGE YOUR MAIDEN NAME REGULARLY
• PUT STRANGE USB DRIVES IN A BAG OF RICE OVERNIGHT
• USE SPECIAL CHARACTERS LIKE & AND %
• ONLY READ CONTENT PUBLISHED THROUGH TOR.COM
• USE A BURNER'S PHONE
• GET AN SSL CERTIFICATE AND STORE IT IN A SAFE PLACE
• IF A BORDER GUARD ASKS TO EXAMINE YOUR LAPTOP, YOU HAVE A LEGAL RIGHT TO CHALLENGE THEM TO A CHESS GAME FOR YOUR SOUL.